

**FUTURE
INTERNS**

API SECURITY RISK ANALYSIS REPORT

prepared by

**SIMAMKELE
SHEYI**

CIN: FIT/APR26/CS7842
Date: May 2026
Internship: Future Interns
– Cyber Security Task 3

INTRODUCTION

APIS POWER MOST MODERN APPLICATIONS INCLUDING MOBILE APPS, WEBSITES, AND SAAS PLATFORMS. IF APIS ARE INSECURE, ATTACKERS CAN STEAL DATA, BYPASS AUTHENTICATION, OR OVERLOAD SYSTEMS.

THIS REPORT ANALYZES A PUBLIC TEST API CALLED JSONPLACEHOLDER. THE GOAL IS TO IDENTIFY SECURITY RISKS, CLASSIFY THEM BY SEVERITY, AND SUGGEST PRACTICAL FIXES THAT A REAL BUSINESS COULD USE.

IMETHODOLOGY

TESTED THE JSONPLACEHOLDER API USING MY WEB BROWSER. I TESTED THE FOLLOWING ENDPOINTS:

- GET /POSTS/1
- GET /POSTS/2
- GET /USERS
- GET /USERS/1
- GET /USERS/2

I LOOKED FOR:

- AUTHENTICATION (DOES IT NEED A PASSWORD OR KEY?)
- AUTHORIZATION (CAN I SEE OTHER PEOPLE'S DATA?)
- EXCESSIVE DATA EXPOSURE (EMAILS, ADDRESSES RETURNED)
- RATE LIMITING (CAN I SPAM THE API?)

FINDINGS / VULNERABILITIES IDENTIFIED

FINDING #1: NO AUTHENTICATION REQUIRED

I ACCESSED THE API USING MY BROWSER. AT NO POINT DID THE API ASK FOR A PASSWORD, API KEY, OR ANY FORM OF LOGIN. ANYONE ON THE INTERNET CAN READ ALL THE DATA.

FINDING #2: IDOR VULNERABILITY

I LOOKED AT /USERS/1 AND SAW USER "LEANNE GRAHAM". I THEN CHANGED THE NUMBER TO /USERS/2 AND SAW A DIFFERENT USER "ERVIN HOWELL". AN ATTACKER COULD GUESS OR COUNT NUMBERS TO STEAL EVERY USER'S INFORMATION.

FINDING #3: EXCESSIVE DATA EXPOSURE

THE /USERS ENDPOINT RETURNS FULL NAMES, EMAIL ADDRESSES, STREET ADDRESSES, AND PHONE NUMBERS. AN APP MIGHT ONLY NEED A NAME, BUT THE API GIVES AWAY TOO MUCH PERSONAL INFORMATION THAT COULD BE USED FOR PHISHING.

FINDING #4: NO RATE LIMITING

I REFRESHED THE /POSTS/1 PAGE QUICKLY MORE THAN 20 TIMES. EVERY REQUEST WAS SUCCESSFUL AND NONE WERE BLOCKED. AN ATTACKER COULD SEND THOUSANDS OF REQUESTS TO FLOOD THE SYSTEM OR GUESS USER IDS.

RISK CLASSIFICATION

Finding	Risk Level	Why
No authentication	High	Anyone can access all data
IDOR vulnerability	High	Attackers can see other users' private
Excessive data exposure	Medium	Emails and addresses could
No rate limiting	Medium	API could be overwhelmed or

RECOMMENDATIONS (REMEDIATION)

FOR NO AUTHENTICATION:

REQUIRE AN API KEY FOR EVERY REQUEST
USE OAUTH OR JWT TOKENS FOR AUTHENTICATED USERS

FOR IDOR:

CHECK IF THE REQUESTING USER OWNS THE DATA BEFORE RETURNING IT
USE RANDOM IDS INSTEAD OF NUMBERS (1,2,3)

For Excessive Data Exposure:

Only return the fields the client actually needs
Don't return emails and addresses unless required

For No Rate Limiting:

Limit requests per IP (e.g., 100 requests per minute)
Return HTTP 429 "Too Many Requests" when limits are exceeded

Verification

Fix Applied	How to Verify
API key required	Try accessing without key - should get 401 Unauthorized
Access controls added	Try accessing another user's ID - should get 403
Rate limiting added	Send 100 fast requests - some should get 429 Too
Data minimized	/users should return only names, not emails

Conclusion

JSONPlaceholder is a test API, so these security weaknesses are expected for learning.
However, the same flaws appear in real-world production APIs.

The main risks were no authentication and IDOR, both High severity. Attackers could access any user's data just by changing a number in the URL.

Real businesses should fix these issues by adding authentication, implementing access controls, limiting data exposure, and adding rate limits.

APPENDIX

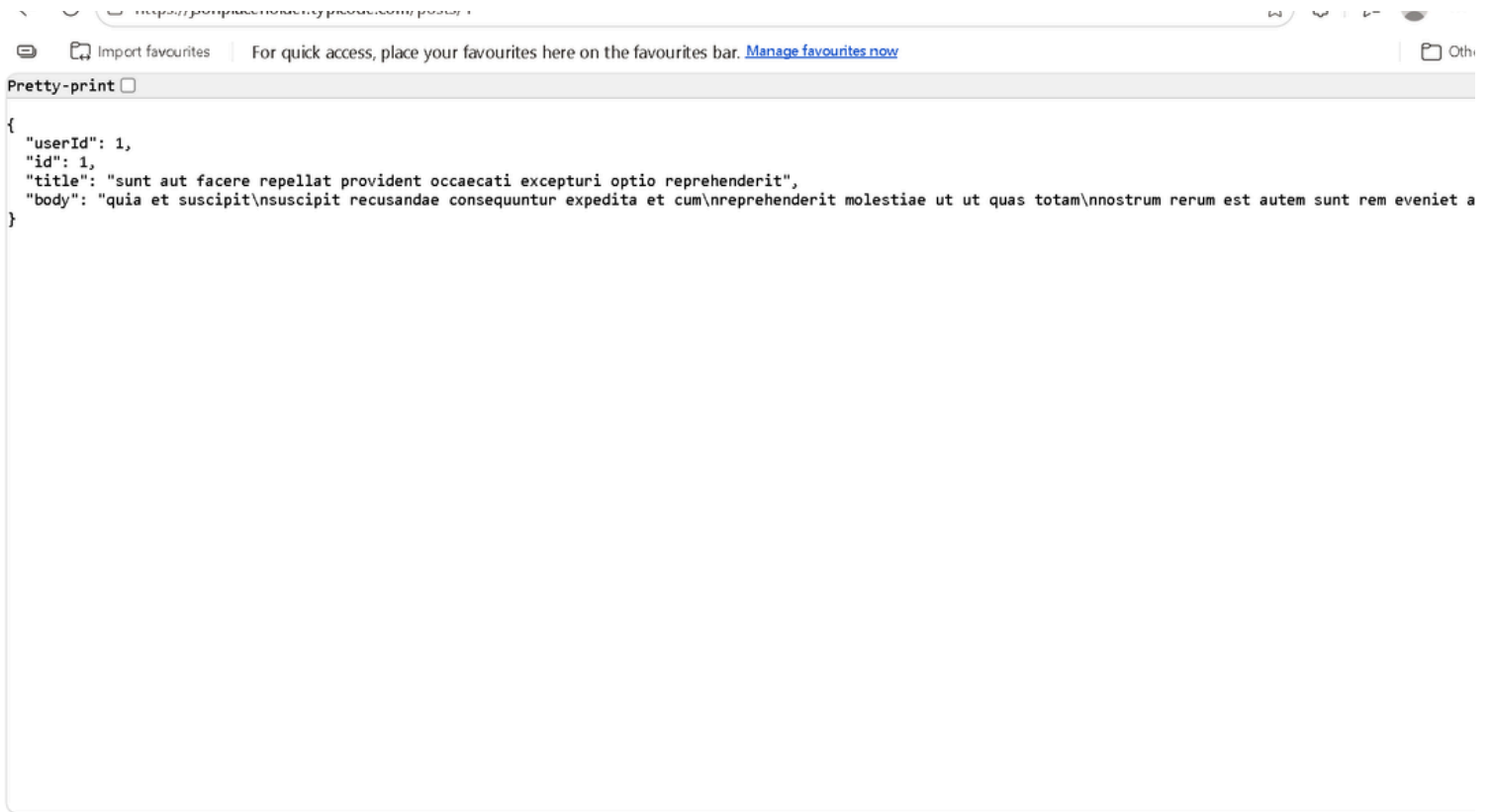


FIGURE 1: GET /POSTS/1 - SHOWING DATA WITH NO LOGIN REQUIRED

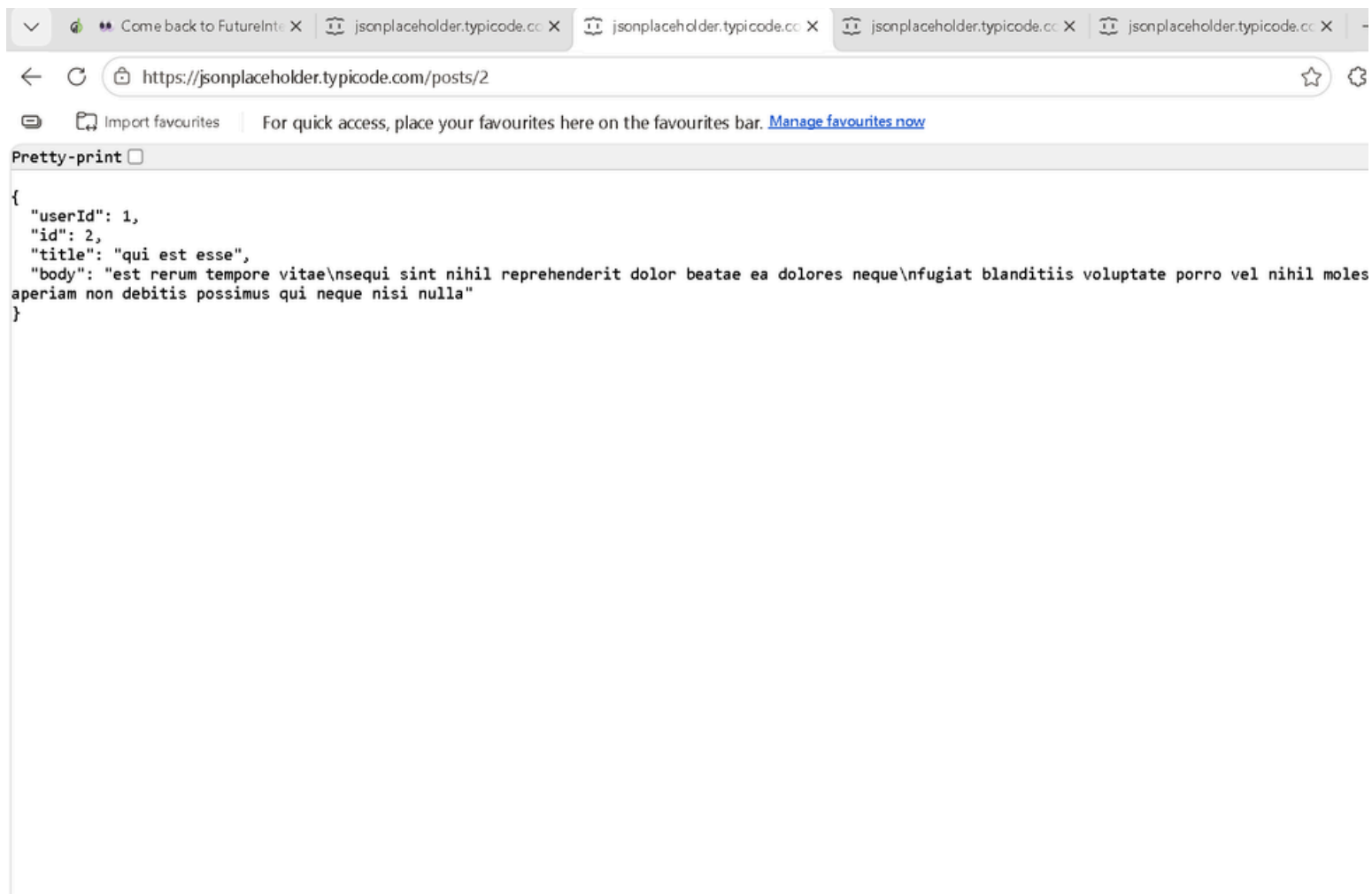


FIGURE 2: GET /POSTS/2 - CHANGING THE ID REVEALS DIFFERENT DATA (IDOR)

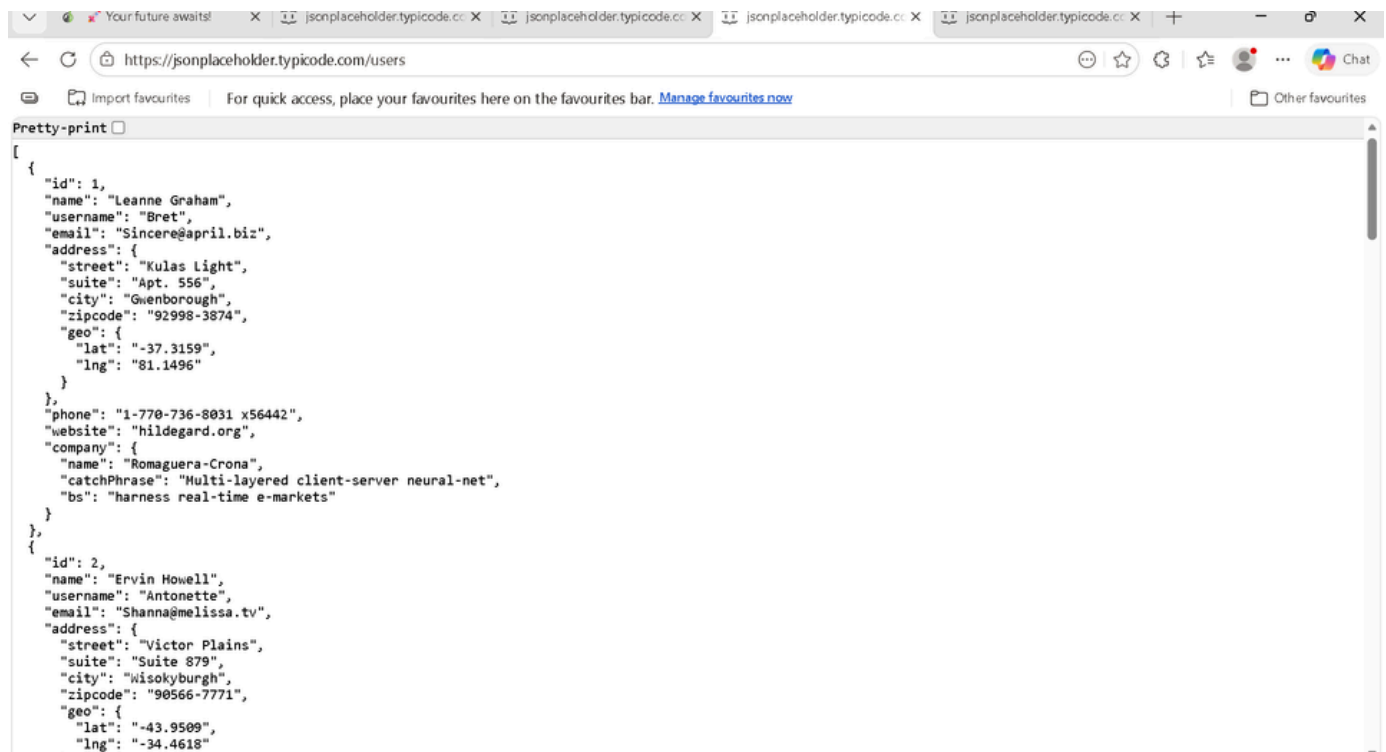


FIGURE 3: GET /USERS - SHOWING ALL USERS WITH EMAILS AND ADDRESSES EXPOSED

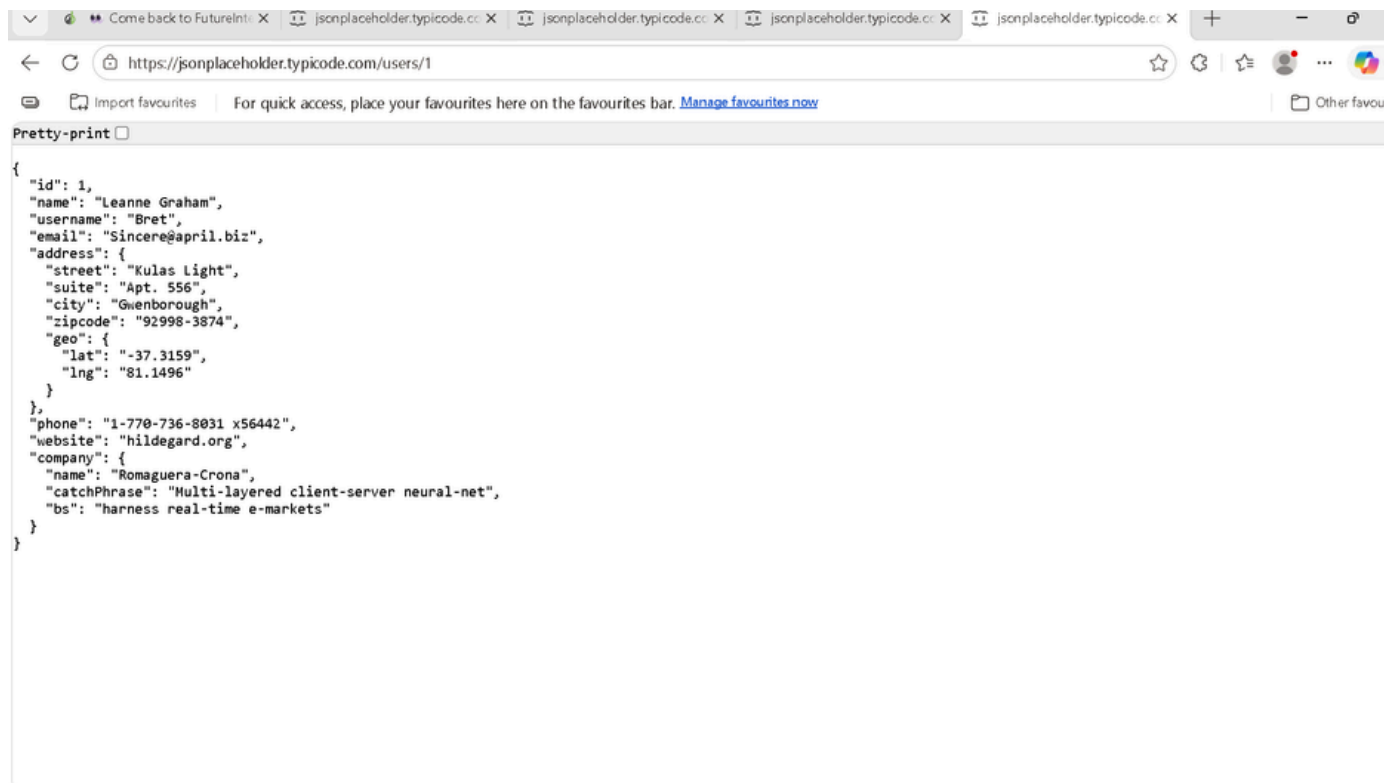


FIGURE 4: GET /USERS/1 AND /USERS/2 - SHOWING DIFFERENT USERS BY CHANGING ID